

Subject: CS987 - Advanced Critical Infrastructure

Name: P. Sivachandran (Roll number: 241560049)

Date: 11th May 2026

Assignment – 1: Breaking the Control Loop: Vulnerability Analysis of a CPS Deployment

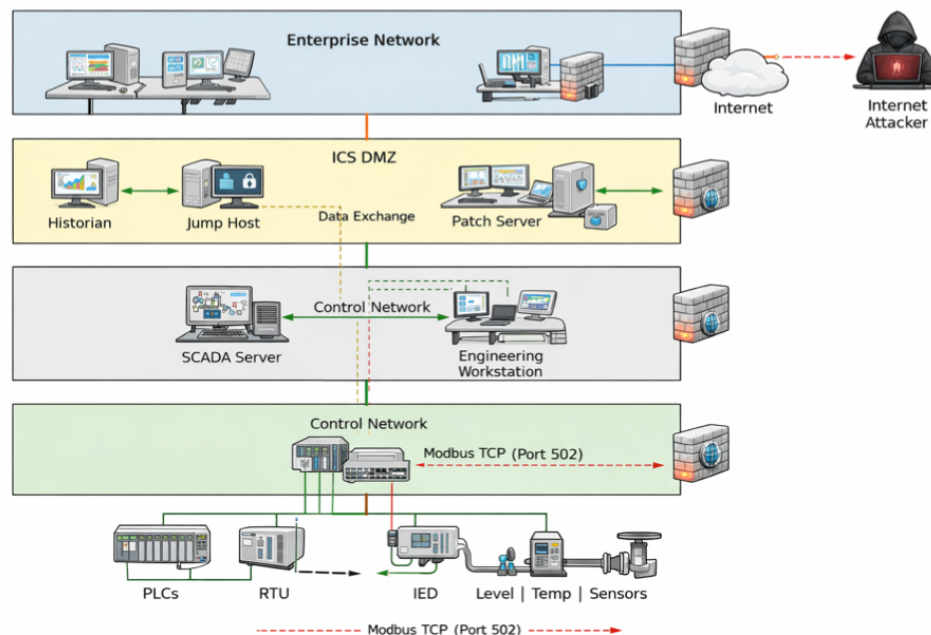


Figure 1: Enterprise and ICS/SCADA network architecture used in the assignment scenario.

Part A: Identification of Critical Weaknesses

Critical Weakness – 1: Unauthorized access

Exact component: ‘Historian server’ & ‘Enterprise network’

Assumed violation: Assuming ‘Historian’ sends benign monitoring data to ‘ICS network’ and could not perform unauthorized access.

How the attacker enables progression: Historian is connected to both Enterprise network and ICS network. While attacker gets unauthorized access to “Enterprise workstation”, which helps to interact with “Historian” which exchanges firewall trusted physical data continuously into “ICS assets”.

Critical Weakness – 2: Unauthenticated Modbus commands

Exact component: PLC Modbus TCP service on 'port 502'

Assumed violation: PLCs assumes valid Modbus 'packets' are sent by any controller

How the attacker enables progression: PLC does not authenticate the sender of 'Modbus commands'. Once hacker reaches 'ICS network', can directly transmit 'Modbus function codes' to modify coils or holding registers. Which may allow attacker to manipulate the outputs 'controlling valves' or 'actuators'.

Critical Weakness – 3: Malicious commands injection

Exact component: PLC Modbus transaction

Assumed violation: PLC assumes all the 'Modbus clients' are benign nature

How the attacker enables progression: Modbus lacks validation of source and transaction authorization, Hacker could inject 'malicious commands' or 'overwrite' legitimate control instructions. It leads to manipulation of 'control variables' but HMI may display normal 'SCADA activity'

Critical Weakness – 4: Firmware Manipulation

Exact component: "Engineering workstation" used for PLC "logic updates".

Assumed violation: "Engineering workstation" assumes logic update activity are legitimate

How the attacker enables progression: "Workstation" enables direct modification of "ladder logic" or "Firmware manipulation", which may reboot or manipulate physical equipment and not protected.

Critical Weakness – 5: Loosely defined Enterprise-to-ICS Firewall Rules

Exact component: Firewall in "Enterprise & ICS networks"

Assumed violation: Administrators assume "segmentation" provides security even though poorly constrained communications

How the attacker enables progression: Loosely defined firewall rules may accept Enterprise connections which may not be necessary. "Segmentation" boundary may enable "unauthorized communication channels" into operational systems.

Part B: Construction of Full Attack Chain

Explaining below about the manipulation of physical process order to cause incorrect 'Actuator' behaviour in pumps or conveyor belts or any other physical system.

1) Initial compromise of Enterprise Workstation

What system interaction is used: In the Enterprise network, attacker targets to execute malware on employee workstation with credentials

Why it succeeds: Enterprise workstation has connectivity with Historian server and accessible firewall approved services and helps to gain access.

What assumption is broken: Assumed that Enterprise compromise does not directly threaten OT systems because segmentation exists

2) Access through Historian server (gains foothold inside the ICS network)

What system interaction is used: Enterprise reachable services are scanned and discovers the Historian server exposing TCP services to Enterprise hosts

Why it succeeds: Historian contains network interfaces with both Enterprise network and ICS networks, and permitted to exchange operational data across the firewall

What assumption is broken: Historian is assumed as passive monitoring component rather than a bridge between trust zones.

3) Discovery of ICS assets (identifies IP addresses of PLCs controlling pumps & conveyors)

What system interaction is used: Attacker tracks devices communicating on Modbus TCP 'port 502' (which may be standard port reserved for Modbus communication), from the Historian or ICS network

Why it succeeds: Industrial protocols are reachable within the 'ICS segment', and to discover traffic PLCs respond as expected

What assumption is broken: In 'ICS network' assumed that all systems are 'trusted participants'

4: Engineering workstation access (privileged access to PLC management functions)

What system interaction is used: Either via "access credentials" or shared administrative access or trust relationships Attacker moves in to 'Engineering workstation'

Why it succeeds: In ICS environment, Engineering workstation is 'highly trusted' and reachable. VPN authentication is the 'primary' security control.

What assumption is broken: System assumes authenticated Engineering access indicates trusted operator.

5: Interaction with Modbus TCP (modification of critical control variables)

What system interaction is used: Attacker sends Modbus TCP write commands directly to PLCs (Example: Function code 05: write Single Coil or Function code 16: write multiple registers)

Why it succeeds: Without performing validation of "authentication or integrity", PLCs used to 'accept' all the valid Modbus requests

What assumption is broken: PLC trusts "all network-originated" Modbus commands.

6: Manipulation of Control logic (altering control decisions)

What system interaction is used: Attacker alters either "Holding register" controls pump threshold or "direct update" of Output coils connected to Moroe pump.

Why it succeeds: PLC interprets that received Modbus values are legitimate process instructions

What assumption is broken: Control logic assumes that either SCADA or authorized Engineering system initiates the commands to execute.

7: Physical component impact (Pump continuous ON status causes water overflow OR Conveyor halt causes production disruption OR Incorrect operation of Valve damages process stability)

What system interaction is used: Actuator control based on modified PLC outputs

Why it succeeds: PLC got direct access control of physical devices (Pump, Conveyor motor, Valves)

What assumption is broken: Physical processes depend on trustworthy digital commands. (impacts loss of view/control, downtime, safety risk)

Part C – Modbus Exploitation

Weakness – I: Modbus TCP does not authenticate the request originated. (PLC validates the packet format, but not validates packet origin or operator authentication)

How it is exploited: Attacker connected to ICS network sends malicious Modbus commands directly to PLC since not authenticated.

Packet-level action performed: In Modbus TCP, attacker transfers malicious packet to PLC. Then PLC updates coil state. (Ex. Incorrect Function Code 05 packet writes coil value 0xFF00 to the coil controlling a pump motor)

Summary of command rule for reference:

Write Single Coil – Function Code 05,

Write Single Register – Function Code 06,

Write Multiple Registers – Function Code 16

Resulting system-level effect: Pump motor controlled unexpectedly causing tank overflow or mechanical damage of physical system.

Weakness – II: Lack of cryptographic integrity check in Modbus TCP, and it does not validate whether a command conflicts with legitimate SCADA activity

How it is exploited: Anyone could inject multiple malicious register update concurrently with normal SCADA polling.

Packet-level action performed: Attacker repeatedly crafts and injects malicious register write packets (Function Code 16), which will modify holding registers that controls the conveyor speed. Accordingly, PLC updates process variables used by Motor control logic.

(PLC cannot distinguish malicious writes from legitimate supervisory traffic, and concurrent transactions are processed without contextual authorization. Example, Conveyor speed control holding register value is updated with higher value)

Resulting system-level effect: Conveyor runs at unsafe speed, could not protect and potentially damages the equipment/physical system.

(Incorrect state → incorrect control → unsafe physical behaviour)

Part D: Défense Design

Défense design – 1: Command whitelisting with Industrial Protocol Gateway (helps to filter out malicious packets before reaching PLC zone)

Specific point in the system: Placed between SCADA network and PLC network

What it blocks: This gateway blocks unauthorized Modbus command codes and allows only approved Modbus function codes & register ranges from specific systems

Limits attacker capability: Even if attacker compromises enterprise or SCADA systems, this gateway enforces restrictions and stops unauthorized write operations/manipulation to critical physical components (pumps, valves or conveyor motors)

Défense design – 2: PLC zone micro-segmentation with identity bound access control to avoid instruction from external interfaces (attacker cannot establish Modbus sessions with PLCs)

Specific point in the system: Inside of ICS network between engineering workstations, SCADA servers, and PLC VLANs

What it blocks: Unauthorized lateral movement and direct PLC access from compromised hosts inside the ICS network

Limits attacker capability: In Historian server or another ICS host, while attacker compromises, they cannot communicate directly with secured PLC network unless their system identity and location match approved security policies.

Défense design – 3: Dedicated Unidirectional Historian Transfer Architecture (Loses trusted bridge in ICS environment since interrupted at initial pivot stage)

Specific point in the system: Between Historian and Enterprise network

What it blocks: It blocks enterprise-originated traffic from entering the ICS network through the Historian pathway

Limits attacker capability: In Enterprise workstation, while malware got compromised, attacker cannot pivot through Historian into operational systems since communication channel physically or logically prevents reverse traffic through this Hardened interior control network.